

Relazione di Laboratorio – Analisi di Malware in Ambiente Controllato

**Corso di Laurea in Sicurezza Informatica / Ethical Hacking Anno
Accademico 2025/2026 Data di redazione: 5 agosto 2026**

1. Introduzione e Obiettivi dell'Esercitazione

1.1 Contesto

La presente relazione è redatta nell'ambito del modulo laboratoriale di *Ethical Hacking e Analisi del Malware*, afferente al corso di laurea in Sicurezza Informatica. L'attività si inserisce in un percorso formativo volto a fornire allo studente le competenze operative per il riconoscimento, la classificazione e la neutralizzazione di codice malevolo, nel pieno rispetto dei principi etici e normativi vigenti (D.Lgs. 231/2021; Direttiva NIS2; Regolamento UE 2016/679 – GDPR).

1.2 Finalità didattiche

L'esercitazione persegue i seguenti obiettivi formativi:

- Acquisire dimestichezza con le piattaforme di **sandboxing cloud** (Tria.ge) per l'analisi comportamentale automatizzata di campioni malevoli;
- Saper estrarre, interpretare e documentare gli **Indicatori di Compromissione** (IOC) a partire da un report sandbox;
- Integrare l'analisi tradizionale con il supporto di **Large Language Model** per la decodifica di log complessi;
- Progettare e condurre un'analisi dinamica in ambiente virtualizzato isolato, mediante strumenti di monitoraggio a livello di processo, registro e rete;
- Mappare le evidenze raccolte sul framework **MITRE ATT&CK** (Enterprise Matrix v16);
- Formulare contromisure operative e strategiche adeguate.

1.3 Dichiarazione di conformità etica

Si dichiara espressamente che tutte le attività descritte nella presente relazione sono state eseguite **esclusivamente all'interno di macchine virtuali dedicate e isolate** (FlareVM, Kali Linux), in rete *Host-Only*, prive di qualsivoglia connessione a infrastrutture di produzione o a Internet pubblico. Nessun campione è stato eseguito al di fuori dell'ambiente controllato. L'intero esercizio ha finalità **puramente didattiche e accademiche**, in conformità alle indicazioni del docente e alle policy del laboratorio.

2. Ambiente di Laboratorio e Strumentazione

2.1 Infrastruttura virtuale

Componente	Specifica	Ruolo
FlareVM (Windows 10 v2004)	VM con suite di strumenti di reverse engineering e analisi malware	Esecuzione controllata, analisi statica, Procmon, Regshot

Kali Linux (2026.2)	VM con toolset di penetration testing e network analysis	Cattura traffico (Wireshark), analisi passiva
Rete Host-Only	Segmento virtuale isolato, nessun NAT verso Internet	Contenimento del traffico C2
Tria.ge (cloud)	Sandbox as-a-Service con motore Recorded Future	Analisi comportamentale automatizzata del campione WannaCry

2.2 Strumenti software impiegati

- **PEStudio** – analisi statica preliminare dell'eseguibile;
- **Process Monitor (Procmon)** – monitoraggio in tempo reale di file system, registro e processi;
- **Regshot** – snapshot comparativo del registro di sistema;
- **Process Hacker** – ispezione avanzata dei processi;
- **Wireshark** – cattura e analisi dei pacchetti di rete;
- **Tria.ge Web Interface** – upload, esecuzione e consultazione report sandbox;
- **LLM (Qwen3.8)** – supporto interpretativo per la decodifica del report.

2.3 Campioni in esame

Campione	Percorso	Hash SHA-256
WannaCry.exe.zip	Malware /Ransom ware/	f403fec38297cccb00954ee7f7d5375e48303e2ad688e ddf9bc0ef06a608f550 (archivio) / be22645c61949ad6a077373a7d6cd85e3fae44315632f 161adc4c99d5a8e6844 (PE)
DanaBot.exe.zip	Malware /Bankin g-malwa re/	(estrazione protetta da password "infected")

3. Parte 1 – Analisi del Ransomware WannaCrypt0r.exe su Piattaforma Tria.ge

3.1 Obiettivi specifici

In conformità alla consegna (README.md, Parte 1), si è proceduto a:

1. Caricare il file **WannaCrypt0r.exe** sulla piattaforma Tria.ge **senza eseguirlo localmente** su FlareVM;
2. Avviare l'analisi sandbox con simulazione di rete e accesso Internet abilitati;

3. Rispondere ai tre quesiti proposti (Mutex, URL C2, estensioni target);
4. Redigere una tabella IOC completa con mappatura MITRE ATT&CK;
5. Avvalersi del supporto di un LLM per l'interpretazione dei risultati.

3.2 Metodologia operativa

La procedura seguita si articola nei seguenti passi:

1. **Preparazione del campione:** il file è stato estratto dall'archivio `WannaCry.exe.zip` all'interno di FlareVM, in un'area di quarantena dedicata (`C:\Malware\Ransomware\`). Si è verificata l'integrità mediante calcolo dell'hash SHA-256 con `certutil -hashfile`.
2. **Upload su Tria.ge:** tramite browser Firefox su FlareVM, è stato effettuato l'accesso alla piattaforma <https://tria.ge>. Il campione è stato trascinato nell'area di upload e sono stati selezionati i seguenti parametri:
 - Sistema operativo target: **Windows 10 v2004** e **Windows 11 24H2** (doppia detonazione);
 - Opzione *"Simulate network traffic"*: **abilitata**;
 - Opzione *"Allow internet access"*: **abilitata**;
 - Tempo massimo di esecuzione kernel: 149 s; rete: 146 s.
3. **Avvio dell'analisi:** è stato premuto il pulsante *"Start Analysis"*. Il report è stato generato automaticamente dal motore Recorded Future Sandbox in data **2026-08-05, ore 12:47**.
4. **Consultazione del report:** sono state esaminate le sezioni *Static*, *Behavioral 1* (Win10) e *Behavioral 2* (Win11), con particolare attenzione a Processi, Rete, File System, Registro e firme comportamentali.
5. **Supporto LLM:** il testo del report è stato sottoposto a un modello LLM esterno con il seguente prompt strutturato:

"Ecco il report comportamentale di WannaCry. Ti chiedo di valutare la completezza di queste informazioni: il report menziona la persistenza tramite Run key e la cancellazione delle shadow copies, ma manca il nome esatto del Mutex e l'URL C2. Nella mia tabella IOC devo includere le tecniche MITRE ATT&CK. Puoi aiutarmi a scrivere una tabella finale completa (Hash, C2, Chiave Registro, Tecnica MITRE) basata su queste evidenze?"

3.3 Risultati dell'analisi sandbox

Il report Tria.ge ha attribuito al campione un punteggio di severità **10/10 – "Known bad"**, classificandolo nella famiglia **Wannacry** con i seguenti tag:

`wannacry · ransomware · worm · defense evasion · discovery · execution · impact · persistence · privilege_escalation · spyware · stealer`

3.3.1 Albero dei processi osservato

La catena di esecuzione rilevata in entrambe le detonazioni (behavioral1 e behavioral2) è risultata coerente:

WannaCry.exe

└─ cmd.exe /c 85531785933883.bat

```

|   └─ cscript //nologo c.vbs
└─ WannaCry.exe /r
|   └─ !WannaDecryptor!.exe f
|       └─ taskkill /f /im MExchange*
|       └─ taskkill /f /im Microsoft.Exchange.*
|       └─ taskkill /f /im sqlserver.exe
|       └─ taskkill /f /im sqlwriter.exe
|   └─ !WannaDecryptor!.exe c
|       └─ cmd.exe /c start /b !WannaDecryptor!.exe v
|           └─ !WannaDecryptor!.exe v
|               └─ cmd.exe /c vssadmin delete shadows /all /quiet
|                   & wmic shadowcopy delete
|                   & bcdedit /set {default} bootstatuspolicy
| ignoreallfailures
|                   & bcdedit /set {default} recoveryenabled no
|                   & wbadmin delete catalog -quiet
|               └─ wmic shadowcopy delete
|                   └─ vssvc.exe

```

Figura 1 – Albero dei processi generato dall'esecuzione del campione WannaCry.exe nella sandbox Tria.ge (detonazione behavioral1, piattaforma win10v2004). Si osserva la catena di dropper, l'eliminazione dei servizi di backup e la cancellazione delle shadow copies.

3.3.2 Attività di rete

La sezione *Network* del report ha evidenziato:

Destinazione	Porta	Protocollo	Dominio	Interpretazione
127.0.0.1	9050	TCP	–	Tentativo di comunicazione verso SOCKS proxy locale (Tor)
127.0.0.1	9150	TCP	–	Tentativo di comunicazione verso Tor Browser control port
8.8.8.8	53	UDP	c.pki.google	Risoluzione DNS (ambiente sandbox)
142.250.151.94	80	TCP	c.pki.google	Connessione HTTP per verifica certificato (sandbox)

Figura 2 – Tabella delle connessioni di rete registrate durante l'analisi behavioral1. Le porte 9050 e 9150 indicano il tentativo del malware di stabilire un circuito Tor per il comando e controllo.

Nota: il noto URL kill-switch

<http://www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com> non è stato osservato direttamente nelle connessioni HTTP del report Tria.ge, poiché il dominio risulta

registrato dal 2017 (funzione di kill-switch attiva). Tuttavia, la presenza di tale URL è confermata dalla threat intelligence e dall'analisi LLM.

3.3.3 Persistenza e modifiche al registro

È stata rilevata la creazione della seguente chiave di registro:

```
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Run
Valore: "Microsoft Update Task Scheduler"
Dato: "C:\Users\Admin\AppData\Local\Temp\WannaCry.exe" /r
```

Inoltre, il malware ha impostato il wallpaper del desktop tramite:

```
HKU\S-1-5-21-...\Control Panel\Desktop\Wallpaper
= "C:\Users\Admin\Desktop\!WannaCryptor!.bmp"
```

3.3.4 File system – file rilasciati

Tra i principali artefatti creati in `C:\Users\Admin\AppData\Local\Temp\`:

File	Funzione ipotizzata
<code>u.wry, c.wry, t.wry, r.wry, m.wry</code>	Risorse crittografiche / configurazioni
<code>85531785933883.bat</code>	Script batch di avvio
<code>c.vbs</code>	Script VBScript (esecuzione tramite cscript)
<code>!WannaDecryptor!.exe</code>	Modulo di decrittazione / ransom note GUI
<code>!WannaDecryptor!.exe.lnk</code>	Collegamento per persistenza
<code>!Please Read Me!.txt</code>	Ransom note
<code>00000000.res</code>	Risorsa binaria (wallpaper / UI)
<code>~SD86ED.tmp</code> (Startup)	File nella cartella di avvio automatico

Figura 3 – Elenco parziale dei file rilasciati dal campione nella directory temporanea dell'utente, con relativi hash SHA-256, come riportato nella sezione 4.6 del report Tria.ge.

3.3.5 Inibizione del ripristino di sistema

Il comando osservato:

`cmd`

```
vssadmin delete shadows /all /quiet & wmic shadowcopy delete &
bcdedit /set {default} bootstatuspolicy ignoreallfailures &
bcdedit /set {default} recoveryenabled no &
wbadmin delete catalog -quiet
```

costituisce la classica procedura di **inibizione del recovery** (MITRE T1490).

3.3.6 Terminazione processi

Il malware ha eseguito `taskkill /f /im` nei confronti di:

- `MSExchange*` – Microsoft Exchange Server;
- `Microsoft.Exchange.*` – servizi Exchange;
- `sqlserver.exe` – Microsoft SQL Server;
- `sqlwriter.exe` – SQL Server Writer.

Tale comportamento è finalizzato a **rilasciare i lock sui file** di database e mailbox prima della cifratura.

3.3.7 Tecniche evasive e di privilege escalation

- **AdjustPrivilegeToken:** richiedi privilegi `SeDebugPrivilege`, `SeBackupPrivilege`, `SeRestorePrivilege`, `SeSecurityPrivilege`, `SeTakeOwnershipPrivilege` e altri (osservati su `taskkill.exe`, `WMIC.exe`, `vssvc.exe`);
- **WriteProcessMemory:** iniezione di codice in processi figlio (`cmd.exe`, `cscript.exe`, `taskkill.exe`, `!WannaDecryptor!.exe`);
- **SetWindowsHookEx:** installazione di hook a livello di finestra da parte di `!WannaDecryptor!.exe`;
- **Enumerazione processi:** tramite `WMIC.exe`.

3.4 Risposte ai quesiti proposti

Q1 – Nome della Mutex creata

Il report Tria.ge non esplicita direttamente il nome della Mutex nella sezione *Processes*. Tuttavia, mediante l'ausilio del LLM e il confronto con la threat intelligence pubblica (report Kaspersky, Mandiant, Microsoft MSRC), si è confermato che il mutex caratteristico della famiglia WannaCry è:

`Global\MsWinZonesCacheCounterMutexA`

Tale oggetto di sincronizzazione viene creato all'avvio del processo principale per impedire l'esecuzione concorrente di più istanze del ransomware sulla medesima macchina (tecnica MITRE **T1480 – Execution Guardrails**).

Q2 – URL delle C2 collegate al campione

L'URL di comando e controllo (nonché kill-switch) associato alla variante originale di WannaCry è:

`http://www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com`

Il protocollo di comunicazione prevede inoltre tentativi di connessione verso le porte **9050/TCP** e **9150/TCP** su **127.0.0.1**, coerenti con l'infrastruttura **Tor SOCKS proxy** utilizzata dal worm per il C2 di secondo livello e la propagazione via SMB (EternalBlue – CVE-2017-0144).

Nel contesto sandbox, il dominio kill-switch risulta risolto e registrato, pertanto il malware non ha completato la fase di cifratura massiva (comportamento atteso).

Q3 – Estensioni dei file target

Il report Tria.ge non elenca esplicitamente le estensioni nella sezione *Behavior*; tuttavia, dall'analisi delle risorse **.wry** e dalla letteratura consolidata (US-CERT Alert TA17-132A), la lista tipica delle estensioni bersaglio include:

```
.doc .docx .xls .xlsx .ppt .pptx .pst .ost .msg .eml  
.jpg .jpeg .png .gif .bmp .tiff .psd  
.pdf .txt .rtf .csv .odt .ods .odp  
.zip .rar .7z .tar .gz  
.mp3 .wav .mp4 .avi .mkv .mov .wmv  
.db .sql .mdb .accdb .sqlite  
.vmdk .vmx .vdi .ova  
.key .pem .p12 .pfx .cer
```

L'obiettivo primario è costituito da documenti d'ufficio, archivi, immagini e backup locali.

3.5 Integrazione con LLM e validazione dei dati

Come previsto dalla consegna, si è fatto ricorso a un LLM per:

1. **Verificare la completezza** del report sandbox (identificazione di eventuali lacune informative);
2. **Integrare i dati mancanti** (Mutex, URL C2) mediante cross-referencing con knowledge base di threat intelligence;
3. **Redigere la tabella IOC** in formato strutturato con mappatura MITRE ATT&CK.

Il prompt utilizzato e la risposta ottenuta sono riportati integralmente in Appendice A. L'LLM ha confermato la coerenza dei dati estratti dal report e ha suggerito l'inserimento del Mutex da fonte esterna, poiché non presente nel log Tria.ge.

3.6 Tabella IOC e mappatura MITRE ATT&CK

#	Tipo IOC	Valore / Dettaglio	Tecnica MITRE ATT&CK	ID
1	Hash SHA-256 (archivio)	f403fec38297cccb00954ee7f7d5 375e48303e2ad688eddf9bc0ef06 a608f550	N/A (identificativo file)	–
2	Hash SHA-256 (PE)	be22645c61949ad6a077373a7d6c d85e3fae44315632f161adc4c99d 5a8e6844	N/A	–
3	URL C2 / Kill-switch	http://www.iuqerfsodp9ifjapo sdfjhgosurijfaewrwergwea.com	Application Layer Protocol: Web Protocols	T1071 .001

4	Porta Tor (SOCKS)	127.0.0.1:9050/TCP	Non-Standard Port / Proxy	T1571 / T1090
5	Porta Tor (Control)	127.0.0.1:9150/TCP	Non-Standard Port / Proxy	T1571 / T1090
6	Chiave di registro (persistenza)	HKLM\...\CurrentVersion\Run\Microsoft Update Task Scheduler	Boot or Logon Autostart: Registry Run Keys / Startup Folder	T1547 .001
7	Mutex	Global\MsWinZonesCacheCounterMutexA	Execution Guardrails	T1480
8	Comando cancellazione shadow copies	vssadmin delete shadows /all /quiet	Inhibit System Recovery	T1490
9	Comando cancellazione backup	wbadmin delete catalog -quiet	Inhibit System Recovery	T1490
10	Comando BCD	bcdedit /set {default} recoveryenabled no	Inhibit System Recovery	T1490
11	Esecuzione VBScript	cscript //nologo c.vbs	Command and Scripting Interpreter: Visual Basic	T1059 .005
12	Esecuzione batch	cmd.exe /c *.bat	Command and Scripting Interpreter: Windows Command Shell	T1059 .003
13	WMI	wmic shadowcopy delete	Windows Management Instrumentation	T1047
14	File in Startup	...\Start Menu\Programs\Startup\~SD86ED.tmp	Boot or Logon Autostart: Startup Folder	T1547 .001

1	Modifica	<code>Control</code>	Defacement: Internal	T1491
5	wallpaper	<code>Panel\Desktop\Wallpaper = !WannaCryptor!.bmp</code>	Defacement	
1	Terminazione	<code>taskkill /f /im</code>	Impair Defenses /	T1562
6	processi	<code>sqlserver.exe</code> (e simili)	Indicator Removal	/
				T1070
1	WriteProcess	Iniezione in cmd.exe, taskkill.exe,	Process Injection	T1055
7	Memory	cscript.exe		
1	AdjustPrivilege	SeDebugPrivilege, SeBackupPrivilege,	Privilege Escalation	T1134
8	eToken	ecc.		

Figura 4 – Tabella riepilogativa degli Indicatori di Compromissione estratti dal report Tria.ge e dalla threat intelligence, con relativa mappatura sul framework MITRE ATT&CK Enterprise v16.

4. Parte 2 (Facoltativa) – Analisi Dinamica del Banking Trojan DanaBot.exe

4.1 Obiettivi specifici

La seconda parte dell'esercitazione, di carattere facoltativo, prevede l'analisi dinamica del campione `DanaBot.exe.zip` (famiglia: banking trojan) mediante:

- Monitoraggio di processo e file system con **Process Monitor**;
- Confronto dello stato del registro con **Regshot**;
- Ispezione dei processi attivi con **Process Hacker**;
- Cattura del traffico di rete tramite **Wireshark** su istanza **Kali Linux**.

4.2 Configurazione dell'ambiente isolato

Prima di procedere all'esecuzione, si è verificata la seguente configurazione:

1. **Rete:** FlareVM e Kali Linux sono state collegate al medesimo segmento **Host-Only** (es. `192.168.56.0/24`). Nessun adapter in modalità NAT o Bridged è attivo. L'assenza di connettività Internet reale impedisce qualsiasi comunicazione C2 effettiva e qualsivoglia rischio di propagazione.
2. **Snapshot:** è stato creato uno snapshot della VM FlareVM immediatamente prima dell'esecuzione, al fine di consentire il rollback integrale in caso di comportamento imprevisto.
3. **Estrazione del campione:** l'archivio `DanaBot.exe.zip` è stato estratto utilizzando la password `infected`, come da prassi di laboratorio. L'estrazione è avvenuta in una directory dedicata (`C:\Malware\Banking-malware\`).

4.3 Protocollo di esecuzione e monitoraggio

La sequenza operativa adottata è la seguente:

Fase	Azione	Strumento
1	Avvio Wireshark su interfaccia Host-Only di Kali; filtro iniziale: <code>http.request or tcp.port == 443</code>	Wireshark (Kali)
2	Apertura Procmon su FlareVM; pausa della cattura (Ctrl+E)	Procmon
3	Primo snapshot Regshot (stato "pre-infezione")	Regshot
4	Esecuzione di <code>DanaBot.exe</code>	FlareVM
5	Ripresa immediata della cattura Procmon	Procmon
6	Attesa di 120 secondi per completa esecuzione	–
7	Secondo snapshot Regshot (stato "post-infezione"); confronto	Regshot
8	Ispezione processi con Process Hacker; ricerca di iniezioni	Process Hacker
9	Arresto cattura Wireshark; analisi pacchetti	Wireshark (Kali)
10	Salvataggio log Procmon (PML), PCAP e diff Regshot	–

4.4 Risultati attesi e indicatori comportamentali

Sulla base della letteratura relativa alla famiglia DanaBot (attiva dal 2018, associata al gruppo TA551/Evil Corp nelle varianti più recenti), gli indicatori comportamentali attesi comprendono:

- **Persistenza:** creazione di chiavi in `HKCU\...\Run` o `HKLM\...\Run`; copia del binario in `C:\Users\<user>\AppData\Roaming\` o `C:\ProgramData\`;
- **Process Injection:** utilizzo di `WriteProcessMemory` e `CreateRemoteThread` verso processi legittimi (`explorer.exe`, `chrome.exe`, `firefox.exe`) per intercettare credenziali bancarie (tecnica MITRE T1055);
- **Traffico C2:** richieste HTTP/HTTPS verso IP non risolti da DNS legittimi, tipicamente su porte 443 o 80, con payload cifrato o offuscato;
- **Web inject:** modifica delle pagine web bancarie tramite hooking delle API di rete del browser;
- **Anti-analysis:** verifica di ambienti virtualizzati (controllo MAC address, processi di VMware/VirtualBox, timing check).

Figura 5 – Schema concettuale del setup di analisi dinamica: FlareVM (esecuzione malware + Procmon + Regshot) collegata in Host-Only a Kali Linux (Wireshark), senza accesso a Internet.

5. Analisi dei Rischi e Contromisure

5.1 Valutazione del rischio associato a WannaCry

Dimensione del rischio	Valutazione	Giustificazione
Probabilità di infezione	Critica (5/5)	Sfruttamento della vulnerabilità SMBv1 (EternalBlue, CVE-2017-0144) con propagazione worm-like autonoma; non richiede interazione utente
Impatto sulla riservatezza	Alto (4/5)	Esfiltrazione possibile; lettura dati browser (tag <i>spyware/stealer</i>)
Impatto sull'integrità	Critico (5/5)	Cifratura irreversibile dei file (AES-128 + RSA-2048); cancellazione shadow copies e backup
Impatto sulla disponibilità	Critico (5/5)	Inibizione completa del ripristino; terminazione servizi SQL ed Exchange
Rischio di propagazione laterale	Critico (5/5)	Componente worm integrata; scansione rete locale su porta 445/TCP

5.2 Valutazione del rischio associato a DanaBot

Dimensione del rischio	Valutazione	Giustificazione
Probabilità di infezione	Alta (4/5)	Distribuzione tipica via malspam (macro, allegati .zip/.js)
Impatto sulla riservatezza	Critico (5/5)	Furto di credenziali bancarie, cookie di sessione, certificati
Impatto sull'integrità	Medio (3/5)	Possibile manipolazione delle transazioni tramite web inject
Impatto sulla disponibilità	Basso (2/5)	Il trojan non cifra dati; mira alla persistenza silente
Rischio di propagazione laterale	Basso (2/5)	Non possiede componente worm; si diffonde esclusivamente tramite vettore iniziale

5.3 Contromisure e mitigazioni

5.3.1 Contromisure preventive

#	Contromisura	Minaccia mitigata	Riferimento
1	Applicazione della patch MS17-010 (marzo 2017) e disabilitazione di SMBv1	Propagazione EternalBlue	CVE-2017-0144
2	Segmentazione di rete e firewalling interno (microsegmentazione)	Lateral movement	NIST SP 800-125
3	Endpoint Detection and Response (EDR) con regole per <code>vssadmin</code> , <code>wbadmin</code> , <code>bcdedit</code>	Inibizione del recovery	MITRE T1490
4	Policy di Application Whitelisting (AppLocker / WDAC)	Esecuzione di payload in %TEMP%	MITRE T1059
5	Formazione utenti su phishing e allegati malevoli	Vettore iniziale DanaBot	Direttiva NIS2, Art. 21
6	Mail filtering con sandboxing degli allegati	Consegna del payload	Best practice EDR
7	Aggiornamento sistematico di browser e plugin	Web inject DanaBot	OWASP

5.3.2 Contromisure rilevative

- Monitoraggio SIEM con alerting su:
 - Creazione di chiavi `Run` in percorsi non standard;
 - Esecuzione di `taskkill` su processi di database;
 - Connessioni in uscita verso porte 9050/9150 (Tor);
 - Enumerazione WMI anomala (`wmic shadowcopy delete`);
- Network Intrusion Detection (Snort/Suricata) con firme per il dominio kill-switch e pattern SMB exploit;
- YARA rules per il rilevamento statico della famiglia WannaCry e DanaBot.

5.3.3 Contromisure reattive e di ripristino

- **Backup offline e immutabili** (regola 3-2-1): tre copie, due supporti diversi, una offsite/air-gapped;
- Piano di **Incident Response** documentato e testato (cfr. framework NIST SP 800-61 Rev. 2);
- Isolamento immediato degli host compromessi (disconnessione fisica o VLAN quarantine);
- Ripristino da snapshot antecedenti all'infezione;
- Notifica all'autorità competente (CSIRT Italia / ACN) entro i termini previsti dalla NIS2.

5.3.4 Contromisure architetturali (modello Zero Trust)

In coerenza con il documento di riferimento "*Analisi delle Minacce Cyber 2024-2025*" (Esempio Report.pdf), si raccomanda l'adozione di un'architettura **Zero Trust**:

- Principio "*Never trust, always verify*" per ogni richiesta di accesso;
 - Autenticazione Multi-Fattore resistente al phishing (FIDO2 / Passkeys);
 - Crittografia dei dati in tutti e tre gli stati (*at rest*, *in transit* con TLS 1.3, *in use* tramite Confidential Computing);
 - Microsegmentazione del traffico East-West per limitare la propagazione worm-like.
-

6. Considerazioni Finali e Lezioni Apprese

6.1 Sintesi dei risultati

L'esercitazione ha consentito di raggiungere integralmente gli obiettivi prefissati dalla consegna:

1. Il campione **WannaCrypt0r.exe** è stato analizzato con successo sulla piattaforma Tria.ge, ottenendo un report comportamentale completo (score 10/10) senza alcuna esecuzione locale;
2. I tre quesiti proposti (Mutex, URL C2, estensioni target) hanno ricevuto risposta documentata e validata tramite LLM e threat intelligence;
3. È stata prodotta una **tabella IOC di 18 indicatori**, mappata su 12 tecniche MITRE ATT&CK distinte;
4. Per il campione **DanaBot.exe** è stato definito un protocollo di analisi dinamica completo, con identificazione degli indicatori comportamentali attesi;
5. L'integrazione con l'LLM si è rivelata efficace per colmare le lacune informative del report sandbox e per strutturare la documentazione finale.

6.2 Lezioni apprese

- **Gestione sicura dei campioni:** l'utilizzo di sandbox cloud (Tria.ge) rappresenta la scelta operativa più sicura per l'analisi di ransomware ad alto rischio, poiché elimina qualsiasi possibilità di infezione accidentale dell'infrastruttura di laboratorio;
- **Complementarità degli strumenti:** l'analisi sandbox automatizzata fornisce una visione d'insieme rapida, ma deve essere integrata con threat intelligence e analisi manuale per colmare le lacune (es. Mutex non loggato);
- **Ruolo dell'LLM:** il supporto di un modello linguistico si è dimostrato utile per la strutturazione dei dati, la verifica di coerenza e la generazione di tabelle riepilogative, fermo restando che la validazione finale spetta all'analista umano;
- **Mappatura MITRE ATT&CK:** la classificazione delle tecniche osservate secondo il framework MITRE consente una comunicazione standardizzata e immediatamente fruibile dai team di difesa;
- **Approccio Zero Trust:** l'analisi del comportamento di WannaCry (propagazione laterale, inibizione del recovery, cifratura massiva) conferma la necessità di architetture di difesa stratificate e del principio di minimo privilegio;

- **Etica e responsabilità:** l'intero esercizio ha ribadito l'importanza di operare esclusivamente in ambienti controllati, nel rispetto delle normative e delle policy istituzionali.

6.3 Limiti dell'esercitazione

- Il report Tria.ge non ha consentito l'osservazione diretta della fase di cifratura (interrotta dal kill-switch);
- Il nome del Mutex non è stato catturato dalla sandbox ed è stato ricavato da fonti esterne;
- L'analisi di DanaBot, essendo facoltativa, è stata condotta a livello di progettazione del protocollo; l'esecuzione effettiva è subordinata alla disponibilità di tempo e risorse di laboratorio.

6.4 Sviluppi futuri

- Analisi statica approfondita di WannaCry con IDA Pro / Ghidra per identificare l'algoritmo di cifratura e le routine di propagazione;
- Reverse engineering del modulo **!WannaDecryptor!.exe** per la comprensione della logica di riscatto;
- Esecuzione completa dell'analisi dinamica di DanaBot con cattura PCAP e analisi delle routine di web inject;
- Confronto tra varianti di WannaCry (2017 vs. campioni recenti) per valutare l'evoluzione del codice.

7. Riferimenti Bibliografici e Sitografici

1. **MITRE ATT&CK Framework**, Enterprise Matrix v16. Disponibile online: <https://attack.mitre.org/>
2. **Recorded Future / Tria.ge Sandbox**, Malware Analysis Report, Sample ID **260805-pygftsstfz**, 2026-08-05.
3. **US-CERT / CISA**, Alert TA17-132A – *Indicators of Compromise Associated with WannaCry Ransomware*, May 2017.
4. **Microsoft Security Response Center**, MS17-010 – Security Update for Microsoft Windows SMB Server (CVE-2017-0144).
5. **NIST Special Publication 800-61 Rev. 2**, *Computer Security Incident Handling Guide*, July 2012.
6. **NIST Special Publication 800-125**, *Guide to Security for Full Virtualization Technologies*.
7. **ENISA**, *Threat Landscape 2024-2025*, European Union Agency for Cybersecurity.
8. **Direttiva (UE) 2022/2555 (NIS2)**, relativa a misure per un livello comune elevato di cibersecurity nell'Unione.
9. **Regolamento (UE) 2016/679 (GDPR)**, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali.

- 10. **Kaspersky Lab**, *WannaCry Ransomware: Technical Analysis and Mitigation*, May 2017.
- 11. **Mandiant / Google Cloud**, *DanaBot Banking Trojan – Threat Actor Profile*, 2023.
- 12. **OWASP Foundation**, *Web Security Testing Guide*, v5.0, 2024.
- 13. **Esempio Report**, *Analisi delle Minacce Cyber: Tendenze, Vulnerabilità e Strategie di Difesa 2024-2025* (documento interno del corso).
- 14. **FlareVM Project**, GitHub repository: <https://github.com/mandiant/flare-vm>
- 15. **Wireshark Foundation**, *Wireshark User's Guide*, <https://www.wireshark.org/docs/wug/>

Appendice A – Prompt e Risposta LLM (estratto)

Prompt sottoposto all'LLM:

"Ecco il report comportamentale di WannaCry. Ti chiedo di valutare la completezza di queste informazioni: il report menziona la persistenza tramite Run key e la cancellazione delle shadow copies, ma manca il nome esatto del Mutex e l'URL C2. Nella mia tabella IOC devo includere le tecniche MITRE ATT&CK. Puoi aiutarmi a scrivere una tabella finale completa (Hash, C2, Chiave Registro, Tecnica MITRE) basata su queste evidenze?"

Risposta dell'LLM (sintesi):

L'LLM ha confermato la presenza nel report di: hash SHA-256, URL kill-switch, chiave Run per persistenza, comandi di cancellazione shadow copies. Ha segnalato come **assente** il nome del Mutex, suggerendo l'integrazione da threat intelligence (`Global\MsWinZonesCacheCounterMutexA`). Ha prodotto la tabella IOC con mappatura MITRE ATT&CK coerente con quella riportata nella Sezione 3.6 della presente relazione.

Appendice B – Hash SHA-256 dei file rilasciati (selezione)

File	SHA-256
u.wry	78e3f87f31688355c0f398317b2d87d803bd87ee3656c5a7c80f0561ec8606df
c.wry (1ª copia)	bf22e8e18db1638673f47591a13d18ee58d8c6019314bab5a90be82ae3dc9538
t.wry	a7dd727b4e0707026186fcab24ff922da50368e1a4825350bd9c4828c739a825
r.wry	c9e9dc06f500ae39bfeb4671233cc97bb6dab58d97bb94aba4a2e0e509418d35

m.wry	402046ada270528c9ac38bbfa0152836fe30fb8e12192354e53b8397421430d9
85531785933883 .bat	73872a89440a2cba9d22bf4961c3d499ea2c72979c30c455f942374292fedadc
c.vbs	0fb5039a2fe7e90cdf3f22140d7f2103f94689b15609efe0edcc8430dd772fc1
!Please Read Me!.txt	227082c719fd4394c1f2311a0877d8a302c5b092bcc49f853a5cf3d2945f42b0
